

**Programming 2B - PROG6212**

**Portfolio of Evidence: Part 1, Section B**

**Ulikhaya A. Mazibuko**

**ST10468748**

# Introduction

This document sets out every endpoint that the RaceDay API will expose. It was written before any of the coding for Part 2 was started which is the point of the exercise because the plan is meant to be the specification that the ASP.NET Core Web API is then built against rather than a description written afterwards.

RaceDay is a web based event management system for the South African road running, walking and cycling community. It supports two roles. An organiser creates and manages events, defines the categories within them, views who has entered and captures results after the race. A participant browses events, enters one by choosing a category, views their own entries and tracks their personal race history.

The API is designed around resources rather than actions, which is the central idea behind REST as originally set out by Fielding (2000). Each thing in the system, an event, a category, an enrolment or a result, is addressed by its own URI, and the HTTP method describes what is being done to it. This keeps the number of routes small and makes their behaviour predictable.

The sections that follow explain the conventions used, list the endpoints grouped by resource, and then set out the reasoning behind the design decisions that are least obvious from the table alone.

# Conventions and Assumptions

## Route naming

Every route begins with `/api/` so that the API is clearly separated from any pages served by the MVC application in Part 3. Collections are named with plural nouns in lowercase, so `/api/events` and `/api/enrolments`, and verbs are avoided in the path because the HTTP method already carries that meaning. Masse (2011) recommends this convention on the grounds that a consistent and predictable naming scheme reduces the amount a developer has to memorise. Anything shown in curly brackets, such as `{id}`, is a value supplied in the URL.

## Roles

The role column takes one of four values. None means the endpoint is public and no login is required. Any means any authenticated user may call it regardless of role. Organiser and Participant mean the endpoint is restricted to that role only.

## Authentication

Authentication is session based, as the Part 2 brief requires. When a user logs in successfully the server stores their user id and role in the session and returns the session cookie, and every request after that is authorised by reading those two values on the server rather than by re-sending the password. Microsoft (2024) documents this session state mechanism as part of ASP.NET Core.

It is worth acknowledging that server side sessions sit slightly outside the statelessness constraint that Fielding (2000) describes as part of REST, since the server is holding conversational state between requests. The assignment brief specifies session management explicitly, so that is what has been planned for, but the tension is a deliberate and understood trade off rather than an oversight.

## Status codes

401 Unauthorized and 403 Forbidden are used to mean two different things and are not interchangeable. 401 means there is no valid session at all, so the caller has not logged in. 403 means the caller is logged in but has the wrong role for that route, or is trying to modify something that does not belong to them. An organiser attempting to edit an event created by a different organiser therefore receives a 403 rather than a 404, because the event does exist and the problem is one of permission. These meanings follow the definitions given in RFC 9110 (Fielding, Nottingham and Reschke, 2022).

409 Conflict is used where a request is well formed but clashes with the current state of the resource, for example when a participant has already entered a category or when entries have closed.

## **Ownership**

Organisers may only modify events they created themselves. The API enforces this by comparing the user id held in the session against the `OrganiserId` column on the event.

## **Nested resources**

Child resources are created through their parent. A category is added with `POST /api/events/{eventId}/categories` because a category cannot exist without an event to belong to. Once it exists it is updated and deleted through its own route, `PUT /api/categories/{id}`, because at that point the identifier on its own is enough to locate it. Richardson and Ruby (2007) describe this as the normal way of expressing a containment relationship in a resource oriented design.

# API Endpoint Plan

## Authentication

| HTTP method | Route              | Description                                                                                                                                            | Role required | Request body                                                                             | Expected response                                                                                                                                                        |
|-------------|--------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| POST        | /api/auth/register | Creates a new account and saves the role the user picked when signing up. The password is hashed before it is saved so the plain text is never stored. | None          | { firstName, lastName, email, password, phoneNumber, dateOfBirth, gender, city, roleId } | 201 Created - returns the new user id and role. 400 Bad Request - a field is missing or invalid. 409 Conflict - that email is already registered.                        |
| POST        | /api/auth/login    | Checks the email and password against the stored hash. If they match, a session is created holding the user id and role.                               | None          | { email, password }                                                                      | 200 OK - returns user id, name and role, and sets the session cookie. 400 Bad Request - email or password not supplied. 401 Unauthorized - the credentials do not match. |
| POST        | /api/auth/logout   | Ends the current session so the user is signed out.                                                                                                    | Any           | None                                                                                     | 204 No Content - the session was cleared. 401 Unauthorized - there was no session to end.                                                                                |
| GET         | /api/auth/session  | Returns who is currently logged in and what role they have. The MVC app in Part 3 uses this to decide which menu to show.                              | Any           | None                                                                                     | 200 OK - returns the user id and role name. 401 Unauthorized - nobody is logged in.                                                                                      |

## User Profile

| HTTP method | Route                  | Description                                                                                                                                             | Role required | Request body                                       | Expected response                                                                                                                                              |
|-------------|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|----------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GET         | /api/users/me          | Returns the profile of whoever is logged in. The user id comes from the session and not from the URL, so a user cannot ask for somebody else's profile. | Any           | None                                               | 200 OK - returns the profile without the password hash. 401 Unauthorized - not logged in.                                                                      |
| PUT         | /api/users/me          | Lets a user update their own details. Email and role cannot be changed here on purpose.                                                                 | Any           | { firstName, lastName, phoneNumber, gender, city } | 200 OK - returns the updated profile. 400 Bad Request - validation failed. 401 Unauthorized - not logged in.                                                   |
| PUT         | /api/users/me/password | Changes the password after checking the current one. The new password is hashed before it is saved.                                                     | Any           | { currentPassword, newPassword }                   | 204 No Content - the password was changed. 400 Bad Request - the new password is too weak. 401 Unauthorized - not logged in, or the current password is wrong. |

## Disciplines

This group is not in the required list given in the brief. It was added during planning because the event type has to be chosen from a fixed list of run, walk and cycle rather than typed in as free text, and the dropdown in the Part 3 interface needs somewhere to fetch that list from.

| HTTP method | Route            | Description                                                                                                                            | Role required | Request body | Expected response                         |
|-------------|------------------|----------------------------------------------------------------------------------------------------------------------------------------|---------------|--------------|-------------------------------------------|
| GET         | /api/disciplines | Returns the list of event types, which are run, walk and cycle. This fills the event type dropdown when an organiser creates an event. | None          | None         | 200 OK - returns the list of disciplines. |

## Events

| HTTP method | Route            | Description                                                                                                                                              | Role required | Request body                                                                                                                                  | Expected response                                                                                                                                                                                                        |
|-------------|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GET         | /api/events      | Returns all published events with the soonest date first. Optional filters ?city=, ?disciplineId= and ?fromDate= let a participant narrow the list down. | None          | None                                                                                                                                          | 200 OK - returns a list of events.                                                                                                                                                                                       |
| GET         | /api/events/{id} | Returns the full details of one event, including the organiser name and the discipline.                                                                  | None          | None                                                                                                                                          | 200 OK - returns the event. 404 Not Found - there is no event with that id.                                                                                                                                              |
| GET         | /api/events/mine | Returns only the events the logged in organiser created. This is what the organiser dashboard in Part 3 is built on.                                     | Organiser     | None                                                                                                                                          | 200 OK - returns the organiser's events. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant.                                                                                                  |
| POST        | /api/events      | Creates a new event owned by the logged in organiser. OrganiserId is taken from the session and not from the request body.                               | Organiser     | { disciplineId, eventName, description, eventDate, startTime, venueName, city, province, latitude, longitude, registrationCloseDate }         | 201 Created - returns the new event and its id. 400 Bad Request - validation failed or the date is in the past. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant.                           |
| PUT         | /api/events/{id} | Updates an event. Only the organiser who created it is allowed to change it.                                                                             | Organiser     | { disciplineId, eventName, description, eventDate, startTime, venueName, city, province, latitude, longitude, registrationCloseDate, status } | 200 OK - returns the updated event. 400 Bad Request - validation failed. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant or does not own the event. 404 Not Found - no event with that id. |

| HTTP method   | Route            | Description                                                                                                                       | Role required | Request body | Expected response                                                                                                                                                                                                                        |
|---------------|------------------|-----------------------------------------------------------------------------------------------------------------------------------|---------------|--------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>DELETE</b> | /api/events/{id} | Deletes an event along with its categories. This is blocked once people have entered so that enrolments and results are not lost. | Organiser     | None         | 204 No Content - the event was deleted. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant or does not own the event. 404 Not Found - no event with that id. 409 Conflict - the event already has enrolments. |

## Categories

| HTTP method | Route                            | Description                                                                                        | Role required | Request body                                                                           | Expected response                                                                                                                                                                                                                                                                                        |
|-------------|----------------------------------|----------------------------------------------------------------------------------------------------|---------------|----------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>GET</b>  | /api/events/{eventId}/categories | Returns every category an event offers so a participant can pick a distance before entering.       | None          | None                                                                                   | 200 OK - returns the categories. 404 Not Found - no event with that id.                                                                                                                                                                                                                                  |
| <b>GET</b>  | /api/categories/{id}             | Returns one category with its event name, entry fee and how many places are left.                  | None          | None                                                                                   | 200 OK - returns the category. 404 Not Found - no category with that id.                                                                                                                                                                                                                                 |
| <b>POST</b> | /api/events/{eventId}/categories | Adds an age or distance category to an event. Only the organiser who owns the event can add to it. | Organiser     | { categoryName, distanceKm, entryFee, categoryStartTime, maxParticipants, minimumAge } | 201 Created - returns the new category and its id. 400 Bad Request - validation failed. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant or does not own the event. 404 Not Found - no event with that id. 409 Conflict - that category name is already used on this event. |

| HTTP method   | Route                | Description                                                                  | Role required | Request body                                                                           | Expected response                                                                                                                                                                                                                                                                        |
|---------------|----------------------|------------------------------------------------------------------------------|---------------|----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>PUT</b>    | /api/categories/{id} | Updates a category name, distance, fee, start time or field limit.           | Organiser     | { categoryName, distanceKm, entryFee, categoryStartTime, maxParticipants, minimumAge } | 200 OK - returns the updated category. 400 Bad Request - validation failed or the new limit is lower than the number already entered. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant or does not own the event. 404 Not Found - no category with that id. |
| <b>DELETE</b> | /api/categories/{id} | Removes a category from an event. Blocked once participants have entered it. | Organiser     | None                                                                                   | 204 No Content - the category was deleted. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant or does not own the event. 404 Not Found - no category with that id. 409 Conflict - the category already has enrolments.                                        |

## Event Enrolments

| HTTP method | Route                                   | Description                                                                                                                                                                                                              | Role required | Request body | Expected response                                                                                                                                                                                                                                                                                            |
|-------------|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|--------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>POST</b> | /api/categories/{categoryId}/enrolments | Enters the logged in participant into a category. Because a category belongs to one event, this records the participant, the event and the chosen category all at once. The server works out the race number and status. | Participant   | None         | 201 Created - returns the enrolment id, race number and status. 401 Unauthorized - not logged in. 403 Forbidden - the caller is an organiser. 404 Not Found - no category with that id. 409 Conflict - already entered, entries have closed, the field is full, or the participant is under the minimum age. |
| <b>GET</b>  | /api/enrolments/mine                    | Returns every event the logged in participant has entered, with the event name, date, category and status.                                                                                                               | Participant   | None         | 200 OK - returns the participant's enrolments. 401 Unauthorized - not logged in. 403 Forbidden - the caller is an organiser.                                                                                                                                                                                 |
| <b>GET</b>  | /api/enrolments/{id}                    | Returns one enrolment. The participant who owns it and the organiser of the event can both see it.                                                                                                                       | Any           | None         | 200 OK - returns the enrolment. 401 Unauthorized - not logged in. 403 Forbidden - the caller does not own the enrolment and does not organise the event. 404 Not Found - no enrolment with that id.                                                                                                          |

| HTTP method   | Route                            | Description                                                                                                                     | Role required | Request body        | Expected response                                                                                                                                                                                                                                           |
|---------------|----------------------------------|---------------------------------------------------------------------------------------------------------------------------------|---------------|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>GET</b>    | /api/events/{eventId}/enrolments | Returns everyone entered into an event with their category and status. This is the organiser's start list.                      | Organiser     | None                | 200 OK - returns the enrolments with participant names. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant or does not own the event. 404 Not Found - no event with that id.                                                     |
| <b>PUT</b>    | /api/enrolments/{id}/status      | Lets the organiser move an enrolment between Pending, Confirmed and Cancelled, for example once the entry fee has come through. | Organiser     | { enrolmentStatus } | 200 OK - returns the updated enrolment. 400 Bad Request - the status value is not recognised. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant or does not own the event. 404 Not Found - no enrolment with that id.           |
| <b>DELETE</b> | /api/enrolments/{id}             | Lets a participant withdraw from an event before it takes place.                                                                | Participant   | None                | 204 No Content - the entry was withdrawn. 401 Unauthorized - not logged in. 403 Forbidden - the caller does not own this enrolment. 404 Not Found - no enrolment with that id. 409 Conflict - the event has already happened or a result has been captured. |

## Results

| HTTP method | Route                                | Description                                                                                                                                                                                     | Role required | Request body                                                      | Expected response                                                                                                                                                                                                                                                                                                                              |
|-------------|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|-------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>POST</b> | /api/enrolments/{enrolmentId}/result | Captures a finish time and finishing positions after the event. It is created against the enrolment because that row already says who ran, which event it was, and which category they were in. | Organiser     | { finishTime, positionOverall, positionInCategory, resultStatus } | 201 Created - returns the new result and its id. 400 Bad Request - validation failed or the event date has not passed yet. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant or does not organise the event. 404 Not Found - no enrolment with that id. 409 Conflict - a result already exists for this enrolment. |
| <b>PUT</b>  | /api/results/{id}                    | Corrects a result that was already captured, for example after a timing query.                                                                                                                  | Organiser     | { finishTime, positionOverall, positionInCategory, resultStatus } | 200 OK - returns the updated result. 400 Bad Request - validation failed. 401 Unauthorized - not logged in. 403 Forbidden - the caller is a participant or does not organise the event. 404 Not Found - no result with that id.                                                                                                                |
| <b>GET</b>  | /api/results/mine                    | Returns the logged in participant's whole race history, showing the event name, date, category, finish time and finishing position.                                                             | Participant   | None                                                              | 200 OK - returns the participant's results. 401 Unauthorized - not logged in. 403 Forbidden - the caller is an organiser.                                                                                                                                                                                                                      |
| <b>GET</b>  | /api/events/{eventId}/results        | Returns the published results for an event in finishing order. This is public so that family and spectators can look up results without an account.                                             | None          | None                                                              | 200 OK - returns the results with names, categories and finish times. 404 Not Found - no event with that id.                                                                                                                                                                                                                                   |

# Summary of Endpoints

| Resource         | Endpoints |
|------------------|-----------|
| Authentication   | 4         |
| User profile     | 3         |
| Disciplines      | 1         |
| Events           | 6         |
| Categories       | 5         |
| Event enrolments | 6         |
| Results          | 4         |
| <b>Total</b>     | <b>29</b> |

All six of the resource groups required by the brief are covered, namely authentication, user profile, events, categories, event enrolments and results. Disciplines is the one additional group identified during planning.

## Design Decisions

### Why an enrolment is posted to a category rather than an event

The brief requires the system to record the link between the participant, the event and the category they selected. A category belongs to exactly one event, so posting to `/api/categories/{categoryId}/enrolments` captures all three of those facts through a single foreign key. Posting to the event instead would have meant sending the category id in the request body and then writing additional code to verify that the category actually belongs to that event, which is a weaker contract and creates a validation problem that need not exist.

### Why the profile and results routes contain no identifier

Routes such as `/api/users/me` and `/api/results/mine` read the user id out of the session rather than from the URL. Because there is no identifier in the path, there is nothing for a user to alter in the address bar, so one participant is structurally unable to retrieve another

participant's profile or race history. Using `/api/users/{id}` instead would require an ownership check on every single call, and a single missed check would expose personal information.

## **Why results can be corrected but not deleted**

There is a PUT for corrections but deliberately no DELETE. A finishing position is a permanent record of what happened on the day, and removing one would make every position below it in the same category incorrect. Where a result was captured in error, the correct action is to update it and set the result status accordingly rather than to erase it.

## **Why 409 Conflict appears so frequently**

Many of the rules in this system concern the state of a resource rather than the validity of the input. A participant may already be entered, entries may have closed, the field may be full, or the event may already have taken place. In each of those cases the request itself is perfectly well formed, so 400 Bad Request would misrepresent what went wrong. RFC 9110 (Fielding, Nottingham and Reschke, 2022) defines 409 as the appropriate response where a request conflicts with the current state of the target resource.

# **Conclusion**

This plan defines twenty nine endpoints across seven resource groups, covering all of the functionality the brief requires along with one additional lookup group identified during planning. The routes follow a consistent naming convention, role restrictions are stated for every endpoint, and both the success and the failure responses are specified so that the behaviour of the API is defined before any code is written.

The value of planning at this level of detail is that the implementation in Part 2 becomes a matter of following a specification rather than making design decisions while writing controllers. It also gives the unit tests something concrete to assert against, particularly the role based access tests, which depend on knowing in advance exactly which status code each rejected request should return.

# Reference List

- Fielding, R.T. (2000) Architectural Styles and the Design of Network-based Software Architectures. PhD thesis. Irvine: University of California.
- Fielding, R.T., Nottingham, M. and Reschke, J. (2022) RFC 9110: HTTP Semantics. Internet Engineering Task Force. Available at: <https://www.rfc-editor.org/rfc/rfc9110> (Accessed: 4 September 2026).
- Masse, M. (2011) REST API Design Rulebook. Sebastopol: O'Reilly Media.
- Microsoft (2024) ASP.NET Core Documentation. Available at: <https://learn.microsoft.com/en-us/aspnet/core/> (Accessed: 4 September 2026).
- Richardson, L. and Ruby, S. (2007) RESTful Web Services. Sebastopol: O'Reilly Media.